CarePass 기능설명서

가족 금융 대리권 지갑 · iM뱅크 앱 내장 기능으로 설계

2026 AI Blockchain Challenge in Daegu 본선 진출작 · 팀 연다(Open)

https://carepass-im.vercel.app

2026년 10월 13일

목차

1. CarePass 기능설명서
2. 01. 시스템 구조
3. 02. 판정 엔진 — judge()
4. 03. 기관 인증과 청구서 검증
5. 04. 블록체인
6. 05. 백엔드와 실사용 모드
7. 06. 확장 기능
8. 07. 데모 시나리오 17종

CarePass 기능설명서

가족 금융 대리권 지갑 · iM뱅크 앱 내장 기능으로 설계 2026 AI Blockchain Challenge in Daegu 본선 진출작 · 팀 연다 (Open)

작성 2026-10-13 · 기준 커밋: 시나리오 17종 전수 검증 통과본

열어보기

	주소	설명
심사용 데모	**https://carepass-im.vercel.app**	왼쪽 폰 화면 + 오른쪽 데모 인스펙터. 로그인 불필요
실사용 모드	**https://carepass-im.vercel.app/app**	데모 장치를 전부 걷어낸 실제 사용 화면. 로그인 필요
서버 상태	https://carepass-im.vercel.app/api/health	`{"ok":true,"storage":"kv"}`

실사용 모드 데모 계정

세 계정이 **하나의 가구(household)** 를 공유합니다. 각자 다른 기기에서 로그인해도 같은 위임을 봅니다.

역할	아이디	비밀번호	이름
위임자 (어머니)	`mother`	`carepass1`	이순자
대리인 (딸)	`daughter`	`carepass2`	이지은
공동보호자 (아들)	`son`	`carepass3`	이준호

> 비밀번호는 환경변수(`CP_PW_*`)로 덮어쓸 수 있습니다. 은행 인증을 대체하려는 것이 아니라 **세션이 서버에서 검증된다는 구조**를 보이는 범위입니다.

한 문단 요약

계좌를 통째로 넘기는 위임이 아니라, **업무별·한도별 금융 대리권**을 만들고 그 행사 내역을 블록체인으로 증명하는 지갑입니다. 어머니(위임자)가 미리 **결제 가능 기관·건당/월 한도·기간**을 정해 위임장에 서명해 두면, 딸(대리인)은 어머니의 카드·비밀번호를 받지 않고 **자기 명의 인증수단**으로 그 범위 안의 의료비만 결제를 요청합니다. 범위를 벗어나거나 평소와 다른 결제는 **보류**되고, 아들(공동보호자)에게 **알림**이 갑니다. 모든 행위의 해시가 온체인에 남습니다.

5분 시연 루트 (처음 보는 사람에게)

심사용 데모(`/`)를 열고 아래 순서로 시나리오 버튼을 누릅니다.

순서	버튼	보여주는 것
1	**iM뱅크 홈**	별도 앱이 아니라 iM뱅크 앱의 한 기능이라는 것

순서	버튼	보여주는 것
2	**위임장 직접 서명**	건별 승인을 없애는 근거 — 설정 시점의 일회성 동의
3	**정상 병원비 8만원**	**신뢰 기관이라 묻지 않고 즉시 승인** — 치매 위임자가 매번 승인할 수 없다는 전제의 답
4	**미등록 결제처(사칭)**	공공데이터로 가짜 병원 차단
5	**청구서 QR · 사칭 검증**	이름까지 베낀 사칭도 **전자서명**으로 구분
6	**한도 아래로 쪼개기(구조화)**	**신뢰 기관인데도 잡힌다** — 면제한 것은 결제처 축 하나뿐 (**킬러 차별점**)
7	**보호자 알림·이의제기**	결제 권한 없는 가족이 감시자로 작동. 집행된 건은 **장부 롤백**까지
8	인스펙터 **블록체인 원장** 탭	실제 Sepolia에서 조회해 해시 대조

3번과 6번을 **붙여서** 보여주는 것이 이 서비스의 핵심입니다. *"믿는 병원은 묻지 않는다"* 와 *"믿는 병원에서도 쪼개면 잡는다"* 가 같이 성립해야 설계가 설명됩니다.

문서 목차

문서	내용
01. 시스템 구조	등장인물 3명, 화면 구성, 상태 모델, 온·오프체인 분리
02. 판정 엔진	`judge()` 규칙 순서, z-score, 구조화 탐지, 반사실 설명, 성능평가 수치
03. 기관 인증과 청구서	공공데이터 결제처 확인, ECDSA P-256 서명 검증, 청구-결제 5항목 매칭
04. 블록체인	`CarePassRegistry` 컨트랙트, salt 해시 프라이버시, 온체인 검증 흐름
05. 백엔드와 실사용 모드	세션·역할 권한·감사 체인·냉각기간 서버 판정
06. 확장 기능	접근성, 은닉 SOS, iM Zero 상담, 월간 리포트, 보안 센터
07. 데모 시나리오 17종	버튼별 동작·기대 판정·검증 결과

구현 범위 (정직하게)

구분	내용
실제로 동작	위임 설정·위임장 서명, 결제요청→판정→알림→승인/거부 전 과정, 규칙+z+구조화 탐지, 신뢰 기관 자동승인·사후 되돌리기, 공공데이터 결제처 확인, **심평원 Open API 실시간 조회(기관 등록 시)**, ECDSA 청구서 서명 검증, Sepolia 온체인 기록·조회, 로그인/세션/역할 권한/감사 체인
화면 시뮬레이션	보안 센터(원격 VC 폐기·후견인 전환), 월간 리포트

구분	내용
설계 발표 범위	실제 은행 코어 API 연동, 생체인증, 다중서명, 신뢰 목록 주기 재점검 배치, 실제 환수(은행 분쟁처리)
데모용 축약	냉각기간 24h → 60초, 결제 이력은 합성 데이터

iM Zero AI 상담은 외부 LLM을 호출하지 않습니다. 현재 위임 상태를 반영한 상태 기반 답변이고, 음성 인식·합성만 브라우저 Web Speech API를 씁니다. 실서비스는 iM뱅크 iM Zero와 연계를 전제로 합니다.

01. 시스템 구조

1. 등장인물 셋 — 권한이 다르다

	이름	역할	할 수 있는 것	할 수 없는 것
위임자	이순자 (어머니)	`delegator`	위임 설정, 위임장 서명, 결제 승인/거부, 위임 정지·복구	—
대리인	이지은 (딸)	`delegate`	결제 **요청**, 한도 상향 **요청**	**승인 불가**
공동보호자	이준호 (아들)	`guardian`	예외 건 **알림 수신**, **이의제기**, 확인	**결제 권한 자체가 없음**

> **보호자에게 결제 권한을 주지 않은 것이 설계의 핵심입니다.** 주는 순간 "판단 능력이 약해진 분에게 매번 확인을 받는다"는 의사능력 모순이 되살아납니다. 보호자는 결제의 당사자가 아니라 **감시자**입니다.

권한은 화면에서만 가리는 것이 아니라 **서버가 거부**합니다 (`api/state.js`의 `ALLOW` 표). 클라이언트를 고쳐도 `403`이 돌아옵니다.

2. 화면 구성

심사용 데모 (`/`)

```
┌──────────────────────┬──────────────────────────────┐
│ iM뱅크 앱 화면        │  데모 인스펙터 (심사용)       │
│ (실제 사용자가 보는 것)│  AI 판단 / 기관 인증 /       │
│                      │  블록체인 원장 / 서브계좌 /   │
│ 상단: 계정 토글 3명    │  컨트랙트                    │
│ 헤더: 가가(큰 글씨)   │                              │
│       🔊(음성 안내)   │  아래: 시나리오 17종 버튼     │
└──────────────────────┴──────────────────────────────┘
```

사용자 화면과 심사 화면을 나눈 이유: 고령자와 가족이 보는 뷰에는 **쉬운 말만** 노출합니다. 판정은 `안전 / 주의 / 확인 필요` 세 가지로만 표시하고 z-score나 μ·σ 같은 기술 지표는 숨깁니다. 그 판단 근거는 인스펙터에서만 확인할 수 있습니다.

실사용 모드 (`/app`)

인스펙터·시나리오 버튼·계정 토글을 전부 걷어내고 폰 화면만 전체로 띄웁니다. **로그인 전에는 아무것도 보이지 않고**, 로그인한 사람의 역할 화면만 보입니다.

3. 돈이 어디에 있는가 — 목적 제한 서브계좌

```
본계좌 (어머니 명의, 1,000만원)
   └ 위임 풀 300만원  ← 격리·불변. 본계좌는 건드리지 않는다
        ├ 병원비   건당 30만 / 월 100만   (허용)
        ├ 공과금   건당 20만 / 월 60만    (허용 · 자동납부)
```

```
      └ 현금송금 ──────────────────  (차단)
  └ 생활비 보호선 50만원  ← 이 아래로 내려가는 결제는 자동 보류
```

에스크로나 선불충전이 아닙니다. 자금은 어머니 명의 계좌에 그대로 남고, 사용 목적과 한도만 제한됩니다. 새 계좌를 만드는 것이 아니라 **쓰던 iM뱅크 계좌에 위임 한도만 얹는 구조**입니다.

값	기본값	코드
위임 풀	3,000,000원	`S.pool.cap`
생활비 보호선	500,000원	`S.protectionFloor`
고액 추가인증 기준	500,000원	`S.coSign`
병원비 건당 / 월	300,000 / 1,000,000	`S.alloc.hospital`
공과금 건당 / 월	200,000 / 600,000	`S.alloc.utility`
현금 송금	**차단**	`S.alloc.cash.allowed=false`

4. 결제 한 건이 흐르는 길

```
① 대리인이 결제 요청
     ↓
② judge() 판정
     ↓
③ 자동승인 조건을 보는가?
     ├ 신뢰 기관 + 정상 + 한도 내   → 즉시 승인. 아무것도 묻지 않음 (보호자 알림함에 기록만)
     ├ 공과금 월 정기 + 정상        → 즉시 승인
     ├ 처음 가는 병원 (정상이어도)   → 보호자 알림 + 위임자 확인
     ├ 평소와 다름 (confirm)       → 보호자 알림 + 위임자 확인
     └ 보류 (hold)                → 결제 안 됨 + 보호자 알림
     ↓
④ 보호자(아들) 이의제기 → 보류 중이면 묶고, **이미 나간 건이면 장부를 되돌림**
     ↓
⑤ 위임자(어머니) 승인 화면 → PIN 인증 → 승인/거부
     ↓
⑥ 온체인 기록 (이벤트 원문의 SHA-256 해시만)
```

일상 결제는 건별로 묻지 않습니다. 위임자가 치매·인지질환이면 건별 승인 자체를 수행하지 못하므로, 매번 묻는 설계는 서비스 전제와 모순입니다. 설정 시점의 위임장 서명으로 동의를 갈음하고, **평소와 다른 건만** 알리거나 보류합니다. 다 물으면 알림 스팸이 되고, 다 자동이면 통제가 없습니다.

4-1. 신뢰 기관 — 무엇을 면제하고 무엇을 면제하지 않는가

"자주 가는 병원은 묻지 않는다"의 정확한 범위입니다.

축	보는 것	신뢰 기관이면
결제처	심평원 등록? 서명 유효?	**면제** — 그것이 신뢰의 의미
금액	평소 대비 편차 (z)	**그대로 검사**
빈도·패턴	한도 아래로 쪼개는가	**그대로 검사**

축	보는 것	신뢰 기관이면
한도	건당·월·생활비 보호선	**그대로 검사**

> **"재검토 없이"가 아니라 "확인 요청 없이"입니다.** 검사는 조용히 다 돌고, 통과하면 묻지 않습니다. 결제처 축까지 끄면 신뢰 기관에서 한도 아래로 쪼개는 공격이 그대로 통과해, 구조화 탐지가 스스로 만든 구멍으로 사라집니다. 실제로 고령자 금융착취는 가짜 병원보다 **진짜 병원에서 과다하게 쓰는 쪽**이 흔합니다.

신뢰 기관은 두 경로로 채워집니다.

경로	내용
(c) 자동	위임 **전에** 위임자가 본인 명의로 결제한 원장에서 **3회 이상 방문한 곳**을 자동 등록
(a) 수동	위임 설정 화면 **"자주 가는 병원 · 확인 없이 결제"** 카드에서 직접 추가·해제

(c)가 **콜드스타트를 그대로 해결합니다.** 실서비스에서 이 데이터는 은행이 이미 보유한 카드·계좌 거래내역에서 나오므로 새로 모을 것이 없습니다.

데모는 그 상태를 **42건짜리 원장**(`PAST_LEDGER`)으로 재현합니다. 판정의 μ·σ도, 신뢰 기관도 **전부 이 원장 하나에서 도출**됩니다 — 하드코딩한 목록이 아닙니다.

기관	종별	횟수	평균	신뢰
대구의료원	종합병원	14	107,071	✅
대구약국	약국	11	49,909	✅
박애의원	의원	9	76,222	✅
경북대학교병원	상급종합	5	188,800	✅
고은재활요양병원	요양병원	2	151,000	— 기준 미달
메디암한방병원	한방병원	1	85,000	— 기준 미달

1~2회만 간 곳은 아직 신뢰가 아닙니다. 가끔 간 곳까지 자동으로 열어주면 신뢰의 근거가 약해집니다. 기관별 평균이 종별 본인부담률 서열과 같은 방향으로 나오는 이유는 02. 판정 엔진의 "기준 분포" 절에 있습니다.

(a)는 **공공데이터 목록에 있는 기관만** 고를 수 있습니다. 손으로 이름을 적게 하면 위임자를 설득해 가짜 병원을 신뢰 목록에 올릴 수 있습니다.

등록된 곳은 대리인 결제 화면에도 버튼으로 뜹니다. 딸이 매번 병원 이름을 검색하지 않고 탭 한 번으로 고릅니다.

> ⚠ 그 버튼 묶음의 라벨은 **"어머니가 등록한 자주 가는 곳"** 이지 *"확인 없이 결제됩니다"* 가 아닙니다. 결제 요청 화면은 **대리인(감시 대상)이 보는 곳**이라, 어디가 마찰이 가장 낮은지 알려주는 것은 반사실 임계값을 노출하는 것과 같은 성격의 문제입니다. 편의만 주고 우회 힌트는 주지 않습니다.

4-2. 사후 되돌리기 — 이미 나간 건

자동승인을 늘리면 "막지 못하고 알림만 가는" 건이 생깁니다. 그 대가를 받는 장치입니다.

층	조치	누가
1. 확산 차단	신뢰 기관 해제 · 대리인 의심 전환(이후 비통지)	**앱이 즉시**
2. 장부 정리	위임 풀 잔액과 월 사용액 **롤백**	**앱이 즉시**
3. 증거 고정	`paymentDisputed` 온체인 기록	**앱이 즉시**
4. 실제 환수	카드 거래취소 · 착오송금 반환	**앱이 못 함** — 은행 분쟁처리·가맹점 동의·법적 절차

2번이 중요한 이유는 성능평가에서 나왔습니다 — '월 한도 초과' 보류 160건 중 **120건이 사기가 한도를 먼저 소진해 뒤따르는 정상 결제가 막힌 연쇄**였습니다. 사기의 2차 피해가 *"어머니가 정작 필요한 병원비를 못 쓰는 것"* 으로 나타납니다. 롤백이 그 연쇄를 끊습니다.

단, 구조화 탐지가 봐야 할 **공격 패턴 증거는 지우지 않습니다.**

5. 위임장 직접 서명 — 건별 승인을 없애는 근거

호주 Banking Code 구조를 옮겼습니다.

요소	내용
위임장 본문	누구에게·무엇을·얼마까지·무엇이 차단인지·누가 입회하는지·위임 ID를 설정값에서 자동 생성
확인 3항목	① 병원비·공과금만 한도 내 위임 ② **대리권 오용 위험과 보호자 알림** 설명 들음 ③ **언제든 철회 가능 · 후견 개시 시 권한 이전**
직접 서명	캔버스 서명 패드 (획을 state에 보관해 재렌더에도 유지)
입회인	공동보호자 이준호(아들)가 기록되고 보호자 알림함에도 남음
온체인	`delegationConsented` — **위임장 해시와 서명 해시만**. 서명 이미지·원문은 전송하지 않음
철회	`delegationConsentRevoked` 기록 후 재서명 요구

서명하지 않으면 위임 설정 화면에 경고가 뜹니다 — *"한도만 정해두면 대리 결제가 시작되지 않습니다"*.

6. 온체인 / 오프체인 분리

온체인에 올라가지 않음	온체인에 올라감	
금액 · 결제처 · 카테고리	이벤트 원문(JSON)의 SHA-256 `dataHash`	
이름 · 계좌번호	위임 조회 키 `SHA-256("위임ID₩	salt")`
위임장 원문 · 서명 이미지	위임장 해시 · 서명 해시	
청구서 원문	인증 기관의 서명 공개키 · 기관명 *(공개 정보라 의도적 공개)*	

자세한 내용은 04. 블록체인 참조.

7. 서버가 없어도 동작한다

ZIP으로 받아 `index.html`을 파일로 열면 백엔드 관련 UI가 **아예 나타나지 않고**, 앱은 로컬 상태로 그대로 동작합니다. 공개 노드에 연결하지 못하면 온체인 검증도 로컬 기록으로 자동 전환되므로 **시연이 멈추지 않습니다.**

02. 판정 엔진 — `judge()`

결제 한 건을 받아 `approve / confirm / hold` 중 하나와 **사람이 읽을 수 있는 사유**를 돌려줍니다. 구현 위치: `carepass-prototype/index.html` 의 `judge(catKey, amount, merchant)`.

1. 규칙이 쌓이는 순서

위에서 아래로 검사하며, **뒤 규칙이 앞 판정을 뒤집지 못합니다**(`level==='normal'` 일 때만 올림).

순	검사	결과
1	청구서 전자서명 불일치 (`sigFail`)	**hold**
2	인증 취소된 기관의 청구서 (`revoked`)	**hold**
3	청구서 금액 ≠ 요청 금액	**hold**
4	미인증 기관 청구서 (`uncertified`)	confirm
5	청구-결제 **기관 불일치**	**hold**
6	청구서 **중복 사용**	**hold**
7	청구서 유효기간(14일) 경과	confirm
8	**미등록 의료기관** (심평원 목록에 없음)	**hold**
9	**구조화(분할 결제) 적중**	**hold**
9'	구조화 경고 (한 번 모자람)	confirm
10	사용처 화이트리스트 위반	**hold**
11	위임 풀 잔액 초과	**hold**
12	생활비 보호선 미달	**hold**
13	건당 한도 초과	**hold**
14	월 누적 한도 초과	**hold**
15	**z ≥ 3**	**hold** *(앞 규칙이 전부 통과했을 때만)*
15'	**z ≥ 2**	confirm *(〃)*
16	고액 구간(≥50만)	confirm

규칙에 하나도 걸리지 않으면 사유에 `규칙 위반 없음 · z=... (정상 범위)` 가 적힙니다.

z-score의 위상 — 중요

z만으로 판단하지 않습니다. z 분기에는 `if(level==='normal')` 조건이 붙어 있어, 앞의 규칙이 하나라도 걸리면 **z는 사유 목록에 증거로만 기록되고 판정을 바꾸지 못합니다.**

다만 **다른 규칙이 전부 통과하고 z ≥ 3이면 z 단독으로 보류**가 됩니다.

상황	z의 역할
사칭·서명실패·매칭불일치·구조화·한도초과·보호선 미달 중 하나라도 해당	증거로 기록만
나머지 규칙 통과 + z ≥ 3	**단독으로 보류**
나머지 규칙 통과 + z ≥ 2	보호자 확인
z < 2	영향 없음

> ⚠ `eval/REPORT.md` 5-6의 **결정 4 2단 설계**(마찰 9.8% → 0.8%)는 *z 단독 보류를 알림으로 내린* 상태에서 계산한 수치입니다. 현재 앱은 보수적으로 **전부 보류**합니다. 발표에서 이 차이를 먼저 밝히는 편이 안전합니다.

1-1. 판정 다음 — 자동승인 조건

`judge()`가 `approve`를 내도 **그것만으로 결제가 집행되지는 않습니다.** 자동 처리 경로는 둘뿐입니다.

```
const autoOK = v.action==='approve' && !v.cosign && v.level==='normal'
               && (S.alloc[catKey].auto || v.trusted);
```

경로	조건
공과금 월 정기	`alloc.utility.auto === true`
병원비 신뢰 기관	`v.trusted` — 과거 본인 결제 이력 또는 위임자가 직접 등록한 곳

어느 쪽이든 **판정이 `normal`이고 고액 구간이 아니어야** 합니다. 즉 금액·빈도·한도 검사를 모두 통과한 건에만 적용됩니다. 신뢰 기관이 면제하는 것은 **결제처 축 하나뿐**입니다.

자동승인된 건은 보호자 알림함에 남지만 배지를 울리지 않습니다(`state:'seen'`). 일상 결제까지 울리면 알림 스팸이 되고 정작 예외가 묻힙니다. 사후에 훑어보고 이의제기할 수 있도록 기록 자체는 남깁니다.

처음 가는 병원은 정상이어도 알린다

```
function needAlert(catKey,v){
  return v.level!=='normal' || v.action==='hold' || (S.alloc[catKey].registry && !v.trusted);
}
```

신뢰 기관이 아니면 판정이 정상이어도 보호자에게 알립니다. 이것이 없으면 그 결제가 **아무에게도 알려지지 않은 채** 위임자 승인만 기다리고, 위임자가 판단하지 못하면 영영 멈춥니다.

실측 동작 (2026-10-13)

케이스	신뢰	판정	결제 상태	보호자 알림
신뢰기관 8만원	O	approve	**즉시 승인**	기록만 (배지 없음)
신뢰기관 **30만원**	O	**hold** (z=4.58)	보류	울림
처음 가는 병원 8만원	—	approve	승인 대기	**"처음 결제하는 병원"**
미등록(사칭) 9만원	—	hold	보류	울림
공과금 6만원	—	approve	**즉시 승인**	기록만

z 임계 3의 근거

관례가 아니라 **오탐율 기준으로 역산**한 값입니다. 평가셋에서 z=3.0은 **오탐율 1.37%** 지점이고, 1% 이하로 조이려면 z ≥ 3.3이 필요한데 그때 정탐율이 2%p 더 떨어집니다.

기준 분포 — μ·σ는 어디서 오는가

μ·σ는 모수를 가정해 얻는 값이 아니라, 위임자 본인의 과거 결제 원장에서 계산되는 값입니다.

```
μ=96,786 / σ=44,396
   ↑ 위임 전 본인 결제 원장 42건의 표본통계 (stats())
   ↑ PAST_LEDGER — 기관·종별·금액·날짜를 가진 실제 원장
   ↑ 금액은 로그정규(중앙값 85,000 · σ_log 0.45) · 고정 시드 rng(20260909)
```

원장 (데모 초기 상태)

기관	종별	횟수	평균	최근	신뢰
대구의료원	종합병원	14	107,071	4일 전	✅
대구약국	약국	11	49,909	17일 전	✅
박애의원	의원	9	76,222	15일 전	✅
경북대학교병원	상급종합	5	188,800	62일 전	✅
고은재활요양병원	요양병원	2	151,000	130일 전	— 기준 미달
메디암한방병원	한방병원	1	85,000	111일 전	— 기준 미달

기관별 평균이 종별 본인부담률 서열과 같은 방향으로 나옵니다 — 상급종합 18.9만 > 요양병원 15.1만

> 종합병원 10.7만 > 의원 7.6만 > 약국 5.0만. 금액 배정을 종별 순서로 했기 때문이고,

그 순서의 근거가 아래 공개 통계입니다.

> 인스펙터 **AI 판단** 탭을 판정 전에 열면 이 원장 표가 그대로 보입니다. *"μ·σ도 신뢰 기관도 전부 이 원장 하나에서 나옵니다"* 를 화면으로 보일 수 있습니다.

공개 통계와 대조 — 근거가 있는 부분과 없는 부분

지표	값	기준
65세 이상 외래 **내원일당 진료비**	63,953원 (2025)	**총진료비** (공단+본인부담)
65~69세 1인당 연간 진료비	4,127,892원	총진료비
70~74세 1인당 연간 진료비	4,985,815원	총진료비

통계의 "진료비"는 총진료비이고, 창구에서 내는 건 본인부담금입니다.

종별	외래 본인부담률	내원일당 환산
의원 (65세 이상)	정액제 — 총액 15,000원 이하 1,500원 / 25,000원 초과 30%	약 19,000원
병원	40% (읍면 35%)	약 26,000원

종별	외래 본인부담률	내원일당 환산
종합병원	50%	약 32,000원
상급종합	진찰료 100% + 나머지 60%	약 38,000원

	근거
분포의 **형태** (로그정규)	✅ 의료비는 오른쪽 꼬리가 긴 분포. 정규분포를 2만~19만으로 **절단**해 쓰면 σ가 과소추정돼 z가 부풀고 오탐이 는다 — 2026-10-07에 발견해 교정, σ 32,155 → **44,396**(+38%)
종별 **서열** (상급종합 > 종합 > 의원 > 약국)	✅ 공개 본인부담률과 방향 일치
분포의 **모수** (중앙값 8.5만 · σ_log 0.45)	❌ **인용할 공개 통계가 없다. 시연을 위해 정한 값이다**

대조 결과 급여 기준으로는 2~4배 높습니다. 연간으로도 모델은 월 2.5회 × 9.4만 = 연 282만원인데 통계상 급여 본인부담은 연 110만원 수준입니다. 다만 **비급여**(건강보험 통계에 안 잡힘), **약제비·요양병원**, 그리고 **타깃이 치매·파킨슨 등 지속 치료 집단**이라는 점이 빠져 있어 설명 가능한 범위이긴 합니다. 그래도 *"통계에 근거했다"* 고는 말할 수 없습니다.

그래서 통계는 '모수의 근거'가 아니라 '콜드스타트 초기값의 근거'로 씁니다

> *"μ·σ는 본인 결제 이력에서 계산합니다. 이력이 없는 가입 초기에는 진료비 통계지표의 내원일당 63,953원에 종별 본인부담률을 적용한 값을 초기값으로 쓰고, 개인 결제가 쌓이면 개인 프로파일로 수렴시킵니다(shrinkage). 데모의 8.5만원은 그 초기값이 아니라 **이미 이력이 쌓인 상태를 재현한 시연값**입니다."*

개인화는 가능하고, 반드시 해야 합니다

집단 모수를 개인에게 적용하면 **어느 쪽으로든 틀립니다.** 노인 의료비는 극단적 우편포라 1인당 평균이 413만원이어도 중위수는 훨씬 낮고 상위 일부가 평균을 끌어올립니다.

집단 평균을 쓰면	결과
의료비가 적은 사람	μ 과대 → z가 작아짐 → **탐지가 둔해짐**
중증 환자	μ 과소 → 정상 결제가 계속 보류 → **마찰 폭증**

은행 데이터로 개인화가 됩니다 — 카드·계좌 거래내역에 결제처와 금액이 있고, **심평원 요양기관 목록과 대조**해 의료 카테고리를 분리하는 것은 이미 구현한 기능입니다. 총진료비가 아닌 **실결제액**이 잡히는 것도 우리가 원하는 방향입니다.

단 네 가지를 설계에 반영해야 합니다.

#	조건	현재
1	**표본 부족** — 월 2.5회면 연 30건. σ 추정이 불안정하다	shrinkage 평가셋에만
2	**drift** — 질환 진행으로 μ가 자연히 오른다. 고정 baseline이면 정상 증가를 이상으로 본다	미구현 (rolling window 필요)
3	**기관 종별 분리** — 의원 2만과 상급종합 4만을 한 분포로 섞으면 σ가 부풀어 탐지가 둔해진다	미구현 (원장에는 종별이 있다)
4	실손보험 환급	z는 결제 시점 기준이라 영향 없음

⚠ 앱에는 콜드스타트 대응이 없습니다

```
const st = h.length ? stats(h) : {mean:amount, std:1, ...};   // 이력 0건이면 z=0
```

평가셋에는 **shrinkage(K=10, 집단 평균으로 축소추정)** 가 들어가 있지만 **앱에는 구현돼 있지 않습니다.** 이력이 없으면 무엇을 결제하든 `z=0`이 나와 금액 축이 사실상 꺼집니다. 데모는 합성 42건으로 시작하므로 드러나지 않지만, 실서비스 가입 첫날이 그 상태입니다. 기관 축·한도 축은 살아 있어 무방비는 아니지만 **먼저 말할 한계**입니다.

2. 구조화(한도 회피) 탐지 — 킬러 차별점

> *"사기범이 한도 바로 아래로 쪼개서 결제하면?"* 에 대한 답입니다. 금액 하나만 보는 z-score로는 **절대 안 잡힙니다.**

```
const STRUCT_WINDOW_DAYS = 7;   // 관찰 창
const STRUCT_NEAR        = 0.9; // 건당 한도의 90% 이상이면 "한도 근접"
const STRUCT_MIN         = 3;   // 창 안에 3회 이상이면 적중
```

판정	조건
`hit` (보류)	이번 결제가 한도 근접 **그리고** 7일 내 근접 결제가 **3회 이상**
`warn` (확인)	같은 조건에서 2회째

시연값: 건당 한도 150,000 / 결제 145,000(97%) / 3일간 반복 → 7일 내 4회, 누적 580,000. 이때 **z = 1.086** 으로 임계(3) 한참 아래입니다 — *"z로는 정상인데 다른 축이 잡는다"* 가 코드에서 사실입니다.

> ⚠ **이 금액은 바꾸면 안 됩니다.** 처음에는 29만원(한도 30만)으로 짰는데 z=6.0이라 z-score도 같이 잡아버려서 주장이 성립하지 않았습니다.

3. 반사실 설명 (XAI) — "무엇이 달랐으면 통과였나"

고령자에게 가장 이해하기 쉬운 설명 형태입니다. 다만 **설명가능성과 우회 가능성이 정면으로 충돌합니다.**

왜 사용자 화면에서 숫자를 뺐나 (2026-10-13)

반사실이 *"₩185,578 이하였으면 통과됐습니다"* 라고 임계값을 찍고 있었습니다. **결제 요청 화면은 대리인이 보는 곳**이라, 이 숫자는 곧 탐지를 피하는 최적 금액이 됩니다.

```
앱이 알려준 185,578 바로 아래, 18만원씩 반복하면
  z      = (180,000 − 96,786) / 44,396 = 1.87   →  임계 2 미만, 통과
  구조화  = 180,000 / 300,000 = 0.60            →  근접 기준 0.9 미만, 미해당
  한도    = 월 100만원 안 → 5건 가능
  결과   = 월 90만원이 아무 경고 없이 빠져나감
```

구조화 사유도 *"건당 한도의 97% 금액이 최근 7일 내 4회 (누적 ₩580,000)"* 로 **탐지 파라미터를 그대로** 알려주고 있었습니다 — 우회 금액과 주기를 앱이 계산해 주는 셈입니다.

사용자 화면 / 심사 화면을 가른다

	폰 화면 (사용자·대리인)	인스펙터 (심사용)
금액 반사실	*"평소 결제 범위 기준을 넘는 금액이라 확인이 필요합니다"*	*"₩185,578 이하였으면 통과됐습니다 (가장 먼저 걸린 기준: 평소 결제 범위)"*
구조화 사유	*"짧은 기간에 한도에 가까운 금액이 반복되고 있습니다"*	근접률·윈도 일수·횟수·누적액 **전부**
빈도 반사실	*"이 결제처를 평소보다 자주 이용하고 있습니다"*	*"이번 주 4회째입니다"*
μ · σ · z	**노출 0**	전부

구현은 `cfLine()` · `userReason()` · `userSay()` 세 함수가 담당하고, 폰 렌더·TTS·서버 전송 경로에 모두 적용됩니다. 인스펙터는 원문을 그대로 받습니다.

비금액 차단 문구는 그대로 둡니다 — *"금액을 낮춰도 통과되지 않습니다 — 결제처 등록 문제입니다."* 우회 정보가 없고, 오히려 금액 조정 시도를 차단하는 메시지입니다.

금액 기준은 네 개 중 **가장 먼저 걸리는 것**을 고릅니다 — 건당 한도 / 월 한도 잔여 / 생활비 보호선 여유 / 평소 결제 범위(μ+2σ).

> **발표에서 쓸 답** — *"XAI로 설명한다면서 숫자를 왜 안 주나요?" "설명가능성과 우회 가능성이 충돌하는 지점입니다. 사용자에게는 방향을, 심사자에게는 숫자를 주도록 화면을 갈랐습니다. 결제 요청 화면은 감시 대상인 대리인이 보는 곳이라, 임계값을 그대로 보여주면 탐지를 피하는 최적 금액을 앱이 알려주는 셈이 됩니다."*

4. 탐지 성능평가

`carepass-prototype/eval/` — 재현: `python gen_dataset.py && python evaluate.py && python make_chart.py`

평가셋: 120가구 × 180일 = 2,833건, 채점 1,985건(이상 162건·8.2%), 앞 60일은 baseline 추정용 번인.

자기충족 회피: 이상치를 '규칙 위반'이 아니라 **사기범의 목표·행동**으로 생성했습니다. 그래서 미탐이 실제로 납니다. 예외 가정은 "구조화 공격자는 화면에 뜨는 건당 한도를 안다" 하나뿐입니다.

안	정탐율	보류율	탐지 오탐율
A 규칙만	82.7%	13.1%	0.0%
B z-score만	**22.2%**	1.4%	0.8%
C 규칙+z (멘토링 시점)	87.0%	13.9%	0.8%
D C+구조화+매칭 (현재 앱)	**91.4%**	13.9%	0.8%
E D+Isolation Forest (오프라인 전용)	93.8%	14.3%	1.2%

발표에서 쓸 수치 5개

1. **C → D: 정탐율 87.0 → 91.4%, 오탐은 1건도 늘지 않았다** (253건 동일)
2. **z 단독은 사칭 5%, 청구서 조작 24%밖에 못 잡는다** — "z를 버린다"가 아니라 **"z는 금액 축 하나로만 쓰고 나머지 축을 따로 만든다"**
3. **한도를 바짝 묶은 가구에서 z의 구조화 정탐율은 정확히 0%** → 구조화 탐지가 메우는 사각지대 (D는 78%)
4. **차단 시점** 2.4번째 → 2.0번째, **유출액 29% 감소**

5. **z=3의 근거** = 오탐율 1.37% 지점

부수 발견

보류의 최대 원인인 '월 누적 한도 초과' 160건 중 **120건이 사기가 한도를 먼저 소진해 뒤따르는 정상 결제가 막힌 연쇄**입니다. 사기의 2차 피해가 *"어머니가 정작 필요한 병원비를 못 쓰는 것"* 으로 나타납니다.

먼저 말할 한계

1. **합성 데이터 자체 평가**이며 실거래 성능이 아닙니다. 이상치 비율 8.2%도 설정값입니다.
2. **분포의 모수(중앙값 8.5만 · σ_log 0.45)에는 인용할 공개 통계가 없습니다.** 형태(로그정규)는

근거가 있지만 숫자는 저희가 정한 값입니다. 실서비스에서는 **본인 거래내역에서 직접 계산**되므로 이 모수가 필요 없어집니다 (위 "기준 분포" 참조).

1. **앱에는 콜드스타트 대응(shrinkage)이 없습니다.** 평가셋에만 있습니다.
2. **E안(Isolation Forest)은 오프라인 평가 전용이고 앱에 탑재하지 않았습니다.**
3. 공격 유형은 상정한 4종뿐입니다.

03. 기관 인증과 청구서 검증

병원 사칭을 **두 겹**으로 막습니다. 첫 겹은 공공데이터, 둘째 겹은 전자서명입니다.

1. 첫 겹 — 공공데이터 결제처 확인

데이터를 **두 가지 방식으로** 씁니다. 역할이 다릅니다.

	내장 스냅샷 (파일)	**Open API (실시간)**
출처	「전국 병의원 및 약국 현황」 2026.6.	병원정보서비스 · 약국정보서비스
범위	대구 5,607곳	전국 · 실시간
쓰는 곳	**결제 판정**	**기관 등록** (신뢰 기관 추가 · 인증 발급)
라이선스	공공누리 제1유형	공공누리 제1유형 · 무료 · 일 10,000회

병원비 항목의 결제처가 목록에 없으면 **금액이 작아도 자동 보류**합니다.

```
결제처 "oo메디컬센터" 90,000원
  → 심평원 요양기관 목록(대구)에 없음
  → hold · "병원을 사칭한 결제일 수 있어 결제를 임시 보류합니다"
```

왜 결제 판정에는 API를 쓰지 않는가

결제는 즉답이어야 하고, 공공 API는 점검·장애가 잦습니다. 판정 경로에 외부 의존성을 넣으면 API가 멈출 때 **사칭 탐지가 통째로 멈춥니다.** 그래서 결제는 스냅샷으로만 판정합니다.

	결제 판정	**기관 등록**
빈도	매 결제	가입 시 몇 번, 이후 가끔
지연 허용	❌ 즉답	✅ "확인 중..." 1~2초
실패하면	**탐지가 통째로 멈춤**	등록만 안 됨. 결제는 영향 없음

등록 시점 조회가 메우는 구멍

스냅샷은 2026.6. 기준이라 **그 뒤 폐업한 기관이 목록에 남아 통과합니다.** 온체인 기관 인증은 폐업을 반영(`revoke`)하는데 결제처 목록은 못 하는 모순이 있었습니다. 등록 시점 조회가 이를 닫습니다.

```
신뢰 기관 추가 / 인증 발급
  → GET /api/hira?region=대구&name=대구의료원
  → 심평원 실시간 조회
     ├ 있음 → 등록. 온체인 사유에 "심평원 Open API 실시간 확인" 기록
     ├ 없음 → 등록 거부. "폐업·휴업일 수 있어 등록하지 않았습니다"
     └ 실패 → 내장 스냅샷으로 그대로 진행 (폴백)
```

실패해도 아무 일도 일어나지 않습니다. 키 미설정·타임아웃·점검·한도 초과 중 무엇이든 내장 목록으로 떨어집니다. 심사장에서 네트워크가 막혀도 동작이 같습니다 (검증: API 없는 환경에서 등록 **10ms** 완료).

프록시를 거치는 이유 — `api/hira.js`

이유	내용
인증키 보호	단일 HTML에 `serviceKey`를 박으면 공개 저장소와 배포본에 그대로 노출됩니다. 계정에 묶인 키라 도용되면 한도가 소진됩니다
CORS	data.go.kr는 브라우저 직접 호출이 막히는 게 일반적입니다
한도 보호	24시간 캐시 + 분당 60회 상한 (일일 10,000회 대비)
키 형식	Encoding/Decoding 키를 `%` 유무로 자동 판별 — 재인코딩하면 인증이 깨집니다
약국 분기	병원 목록에 없으면 약국 API를 자동으로 조회합니다 (별도 서비스)
지역 필터	`yadmNm`은 **부분일치**라 "대구약국"에 포항·의성 약국까지 딸려 옵니다. 주소로 좁힙니다 (전국 10건 → 대구 4건)

`/api/health`가 `"hira": true/false`로 **키 설정 여부만** 알립니다. 값은 내보내지 않습니다.

> **다음 단계** — 등록 **후에** 폐업한 기관은 신뢰 목록에 남습니다. 신뢰 기관은 묻지 않고 승인하므로 오히려 더 위험합니다. **신뢰 목록만 하루 1회 재점검**해 폐업이 확인되면 자동으로 신뢰를 해제하고 온체인 인증도 `revoke`하는 배치가 필요합니다. 결제 경로가 아니므로 지연·가용성 문제가 없고, 서버가 기관 마스터를 갱신하는 형태면 **호출량이 가구 수와 무관**해집니다.

첫 겹의 한계는 그대로입니다. 목록에 있는 **이름을 그대로 베끼면** 통과합니다. 그래서 둘째 겹이 필요합니다.

2. 둘째 겹 — 기관 전자서명

구조

```
① 심평원 목록으로 실재가 확인된 기관에 인증 발급
     ↓ 기관 식별자  instId = SHA-256("기관명|종별|구군")   (기관명은 공백 제거)
     ↓ 인증 근거    proofHash = SHA-256(요양기관 목록 해당 행)
② 기관의 서명 공개키(ECDSA P-256의 X·Y 좌표)를 온체인에 등록
③ 병원이 청구서에 전자서명 → QR로 전달
④ 앱이 온체인에서 공개키를 조회해 WebCrypto로 서명 검증
```

서명 대상 원문

키 순서가 서명·검증 양쪽에서 같아야 하므로 고정합니다 (`sig` 자신은 제외).

```
JSON.stringify({ v, invNo, instId, inst, type, gu, cat, amount, items, issuedAt, nonce })
```

공개키 출처 3단 폴백

표시	의미
`onchain`	**온체인 인증 목록에서 병원 공개키를 조회**했습니다
`builtin`	노드에 연결하지 못해 **앱에 내장된** 인증 목록으로 확인했습니다
`local`	**이 단말에서 발급한** 인증으로 확인했습니다 (인스펙터에서 직접 발급한 경우)

온체인 조회는 `institutionKey(bytes32)` (셀렉터 `0x81322425`)를 `eth_call`로 읽습니다.

검증 결과 4종

chk	의미	판정
`ok`	등록 공개키와 서명이 일치	통과
`sigFail`	**이름은 같은데 서명이 맞지 않음** — 사칭	**hold**
`revoked`	인증이 취소된 기관 (폐업·자격정지·키 유출)	**hold**
`uncertified`	서명을 검증할 공개키가 인증 목록에 없음	confirm

> 데모에는 **진짜 청구서**와 **이름까지 베낀 사칭 청구서**가 들어 있습니다. 둘 다 "대구의료원"이라고 적혀 있지만, 사칭본은 서명 검증에서 걸립니다.

인증 취소도 체인에 남는다

`revokeInstitution(instId, reason)` — 폐업·자격정지·서명키 유출 시 호출합니다. 취소 이력 자체가 온체인에 남고, 취소된 기관은 **새 서명키로 다시 인증받을 수 있습니다**(자격 회복·키 교체).

실제 기록: ○○재활요양병원(시연용) 인증 취소

3. 청구-결제 매칭 — 5항목 대조

서명이 통과해도 **청구서와 실제 결제가 다를 수 있습니다.** 그 구멍을 탐지로 바꿨습니다.

#	항목	검사	불일치 시
1	기관 전자서명	등록 공개키와 일치하는가	**hold**
2	발행 기관 ↔ 결제처	청구서 발행 병원 = 결제처인가	**hold**
3	청구 금액 ↔ 결제 금액	금액이 같은가	**hold**
4	발행일	0일 ≤ 경과 ≤ **14일** (미래 날짜도 거부)	confirm
5	중복 사용	이미 결제에 쓰인 청구서 번호인가	**hold**

승인되면 해당 청구서 번호를 **소모 처리**(`S.usedInv`)해서 재사용을 막습니다.

왜 OCR이 필요 없는가

청구서 QR에 **기관·금액·날짜·청구서번호가 담긴 서명 payload**가 이미 들어 있습니다. 결제 요청과 **필드 대조만 하면** 매칭이 성립합니다. 종이 영수증 OCR은 실서비스 확장 범위이고 이 프로토타입의 구현 범위가 아닙니다.

막아내는 수법

```
수법: 병원 A가 서명한 진짜 청구서를 들고, 결제처만 병원 B로 바꿔 결제
      → 서명은 유효하므로 1번 검사는 통과
      → 2번(발행 기관 ↔ 결제처)에서 걸림 → hold
```

이 시나리오의 **z-score는 0.52** 입니다. 금액만 보는 축으로는 전혀 잡히지 않습니다.

04. 블록체인

1. 배포 정보

항목	값
네트워크	Ethereum **Sepolia** 테스트넷 (chainId 11155111)
컨트랙트	`0xcb421360C1f64384CFE65d9FCB67efe6446e91aB` — Etherscan 소스 검증 완료
배포 블록	11863983 (2026-10-07)
기록 계정	`0x0E00cB50396Bf3a3cdC80efab74bEaDeE501001F`
위임 조회 키	`0xd6759699…000caf19` (salt 적용본)

시연 초기 이력 3건 — 위임 설정 · 병원비 승인 · 공과금 자동승인

기관 인증 — 대구의료원 · 경북대학교병원 · 인증 취소

> 이전 버전 `0x760394Add…` (v2) · `0x9fDa39…` (v1)은 **폐기**되었습니다. 참조하지 마세요.

2. 컨트랙트 — `CarePassRegistry`

두 가지를 담는 **공개 장부**입니다.

① 위임·결제 이력

```
struct Record {
    bytes32 dataHash;  // 오프체인 이벤트 원문(JSON)의 SHA-256
    uint256 ts;        // 기록된 블록 시각
    string  fn;        // 이벤트 종류
}
registerDelegation(bytes32 id, bytes32 dataHash, string fn)   // 기록 계정만
getHistory(bytes32 id) → Record[]                              // 누구나 조회
```

② 의료기관 인증 — 여러 은행·결제대행사·지자체가 함께 조회하는 공용 명부

```
struct Institution {
    bytes32 keyX, keyY;   // 기관 서명키(ECDSA P-256) 공개키 좌표
    bytes32 proofHash;    // 인증 근거(심평원 목록 해당 행)의 SHA-256
    uint64  issuedAt;     // 0 = 발급된 적 없음
    uint64  revokedAt;    // 0 = 유효
    string  name;         // 기관명 (공개 정보)
}
certifyInstitution(...)  / revokeInstitution(...)   // 기록 계정만
institutionKey(bytes32)  / isCertified(bytes32)     // 누구나 조회
```

권한 모델

	registerDelegation · certifyInstitution · revokeInstitution	getHistory · institutionKey
누가	**기록 계정(recorder)만** — 실서비스에서는 은행 기록 서버 키	**누구나**
왜	제3자가 가짜 이력이나 가짜 인증 기관을 끼워 넣지 못하게	제3자 검증 가능성 확보

3. 기록되는 이벤트 종류

이벤트	언제
`delegationConfigured`	위임 설정
`delegationConsented` / `delegationConsentRevoked`	위임장 서명 / 철회
`paymentRequested` / `paymentApproved` / `paymentRejected` / `paymentHeld`	결제 흐름
`limitRaiseRequested`	한도 상향 요청(냉각기간 시작)
`guardianNotified` / `guardianObjection` / `guardianAcknowledged`	보호자 알림·이의제기·확인
`sosAlert`	은닉 SOS
`delegationRevoked` / `guardianTransfer`	위임 정지 / 법정후견인 전환

4. 프라이버시 — 오픈 체인인데 결제내역이 안 보이는 이유

원문은 처음부터 올리지 않는다

온체인에 올라가지 않음	온체인에 올라감
금액 · 결제처 · 카테고리	이벤트 원문의 SHA-256 `dataHash`
이름 · 계좌번호	위임 조회 키
위임장 원문 · 서명 이미지	위임장 해시 · 서명 해시
청구서 원문	기관 공개키 · 기관명 *(공개 정보라 의도적)*

해시는 **한 방향**입니다. 나중에 다툼이 생기면 금고에서 원문을 꺼내 해시를 다시 떠서 체인의 것과 맞춰보면 됩니다 — **내용은 보여주지 않고 진짜라는 것만 증명**합니다.

조회 키에 salt를 섞는다 (2026-10-07 적용)

```
전  →  key = SHA-256("DLG-2026-0914")                    ← 후보 수천 개, 전수 대입으로 복원
후  →  key = SHA-256("DLG-2026-0914|7b41e9d2a8c05f36")    ← salt를 모르면 특정 불가
                                  └ 위임별 난수. 오프체인(은행)에만 보관
```

위임 ID가 `DLG-연도-월일` 형식이라 **후보가 수천 개뿐**이었습니다. 해시가 약한 게 아니라 **재료의 후보가 적은 것**이 문제였습니다(현관 비밀번호를 생일로 둔 것과 같습니다). 규칙은 `contracts/scripts/hash.js` 의 `delegationKey()` 에 있고, 프런트엔드와 동일합니다.

아직 가려지지 않는 것 — 정직하게

체인은 **여전히 공개**입니다. 읽는 것을 막은 것이 아닙니다.

복원 불가	아직 노출
금액 · 기관 · 사람 · 위임 내용	이벤트 **건수**
	블록 **타임스탬프**
	이벤트 **종류** — `string fn`이 평문

일기 내용은 안 보이지만, 일기를 몇 번 언제 썼는지는 보이는 상태입니다. 특히 `sosAlert`가 평문으로 남는 것은 은닉 SOS의 전제와 모순입니다 — 다음 단계에서 코드화합니다. (현재 Sepolia에 실제 기록된 3건은 `delegationConfigured` · `paymentApproved` 뿐이고 런타임 이벤트는 로컬 시뮬레이션이라 라이브 결함은 아닙니다.)

5. 온체인 검증 흐름 — 화면이 실제로 체인을 읽는다

```
페이지 로드
  → 공개 노드(publicnode)에 eth_call: getHistory(delegationKey)
  → ABI 디코딩 (bytes32 dataHash, uint256 ts, string fn)[]
  → 원문(contracts/demo-events.json)으로 다시 계산한 SHA-256과 대조
  → 인스펙터 '블록체인 원장' 탭에 verified / mismatch / offline 표시
```

RPC 타임아웃은 7초이고, 목록의 노드를 순서대로 시도합니다. **전부 실패하면 `offline`로 떨어지고 로컬 기록으로 자동 전환**되므로 시연이 멈추지 않습니다.

> 2026-10-13 전수 검증 시점 기준 실제 조회 결과: **`verified` · 온체인 3건**

6. 단계별 업그레이드 경로

가스비와 메타데이터 노출을 **한 구조로** 해결합니다. 자세한 내용은 `1005 멘토링/체인_로드맵.md` (산출물 8)에 있습니다.

	체인	기록 단위	가스비	프라이버시
Phase 1 현재	Sepolia 공개 테스트넷	결제 건당	0 (테스트 ETH)	salt 해시
Phase 2 파일럿	허가형 **Besu** (은행·병원·심평원·지자체 컨소시엄)	건당	**0**	조회 권한이 노드 참여자 한정
Phase 3 상용	Besu + 공개체인 **하루 1회 Merkle 루트 앵커링**	하루 1건	월 ~7만원 고정	건수·시각·종류까지 사라짐

실측 가스 (2026-10-13, 로컬 Hardhat, EVM paris)

함수	gas
`registerDelegation` (2건째 이후)	98,576
`registerDelegation` (첫 기록)	115,736
`certifyInstitution`	183,051

함수	gas
컨트랙트 배포	877,410
`anchorDay` (Phase 3 루트 1개)	**46,197**

10 gwei · ETH 500만원 가정 시 **1만 가구 월 가스비가 4.9억 → 6.9만원(약 7,100배)**. **"이더리움이 비싼 게 아니라, 건별로 올리는 게 비싸다"** 가 답입니다.

7. 테스트

```
cd carepass-prototype/contracts
npx hardhat test        # 14건 통과
```

05. 백엔드와 실사용 모드

멘토 지적 *"백엔드 + 로그인 + 배포 — 실제로 열어보게"* 에 대한 대응입니다. Vercel 서버리스 함수 4개로 구성되어 있습니다 (`carepass-prototype/api/`).

1. 왜 서버가 필요한가

> **데모 계정 3개가 하나의 가구(household)를 공유합니다.** 어머니가 권한을 주고, 딸이 결제를 요청하고, 아들이 예외만 통지받습니다. **세 사람이 각자 기기에서 로그인해도 같은 데이터를 봅니다** — 그것이 이 서버의 존재 이유입니다.

2. 엔드포인트

경로	역할
`GET /api/health`	배포 확인 · 저장소 모드 보고 → `{"ok":true,"storage":"kv"}`
`/api/session`	로그인 · 세션 조회 · 로그아웃
`/api/state`	가구 공유 상태 (위임 하나를 세 계정이 같이 본다). rev 기반 폴링
`GET /api/audit`	가구 공유 감사 로그 조회 (최근 100건)
`GET /api/hira`	**심평원 요양기관 실시간 조회 프록시.** 기관 등록 시점에만 호출되고 결제 판정에는 쓰지 않습니다 → 03. 기관 인증

3. 인증 — 서버가 검증한다

- 아이디+비밀번호를 **서버가** 확인합니다.
- 비밀번호는 길이가 달라도 타이밍이 새지 않도록 **SHA-256 해시를 떠서 상수시간 비교**합니다

(`crypto.timingSafeEqual`).

- 존재하지 않는 아이디도 더미 값과 비교해 **아이디/비밀번호를 구분해 거부하지 않습니다.**
- 세션은 **HMAC-SHA256 서명된 HttpOnly 쿠키**입니다. 만료 7일.

서명 비교도 상수시간이고, 길이가 다르면 즉시 거부합니다.

```
토큰 = base64url({a: 계정, iat, exp}) + "." + HMAC-SHA256(본문, SESSION_SECRET)
```

환경변수: `SESSION_SECRET` , `CP_PW_DELEGATOR` / `CP_PW_DELEGATE` / `CP_PW_GUARDIAN` , 그리고 **`HIRA_API_KEY`** (심평원 Open API 인증키 — 서버에만 두고 브라우저로 내려보내지 않습니다)

4. 역할 권한 — 클라이언트를 고쳐도 서버가 막는다

`api/state.js` 의 `ALLOW` 표가 action별 허용 역할을 고정합니다.

action	허용 역할
`setup` · `consent` · `consentRevoke`	**위임자만**
`request`	**대리인만**
`decide` (승인/거부) · `revoke` · `restore` · `sos`	**위임자만**
`objection` · `ack`	**공동보호자만**
`raise` (한도 상향 요청)	**대리인만**
`raiseCancel`	위임자 또는 대리인

위반하면 `403` + `"공동보호자은(는) 'decide' 권한이 없습니다"` 식의 메시지가 돌아옵니다.

> **대리인은 '요청'만 하고 승인할 수 없습니다. 보호자는 결제 권한이 아예 없습니다.** 이것이 화면 제어가 아니라 서버 규칙이라는 점이 중요합니다.

5. 감사 로그 — 해시 체인으로 묶는다

서버가 수신 시각과 **직전 항목의 해시**를 엮어 체인을 만듭니다.

```
entry.chain = sha256( (직전 항목의 chain 또는 "000…0") + JSON.stringify(entry) )
```

중간 한 건을 지우거나 바꾸면 **뒤가 전부 어긋납니다.** 세 계정이 같은 로그를 보므로 "누가 무엇을 했는지"를 함께 확인합니다.

6. 냉각기간 — 서버가 판정한다

한도 상향은 즉시 반영되지 않고 **냉각기간**을 거칩니다.

항목	값
기본 길이	**60초** (실서비스 24h의 데모 축약)
환경변수	`CP_RAISE_MS` 로 조정 (테스트에서 기다리지 않아도 됨)
상향 요청	대리인이 요청 → 위임자·대리인 모두 취소 가능
알림	신뢰인(사회복지사 김민서)과 공동보호자에게 통지
온체인	`limitRaiseRequested` 기록

서버리스라 타이머를 둘 수 없으므로, 냉각기간이 끝난 상향은 **읽는 시점에** 반영합니다 (`settleRaise()`). 로컬 타이머로 한도를 바꾸면 다음 폴링에 서버 값으로 되돌아가기 때문에, 앱 모드에서는 상향도 종료 판정도 모두 서버가 담당합니다.

7. 저장소

조건	동작
`KV_REST_API_URL` · `KV_REST_API_TOKEN` 있음	**Vercel KV에 영구 저장** (현재 배포본)
없음	인스턴스 메모리 사용 + 화면에 *"서버 재시작 시 비워진다"* 고 그대로 표시

현재 배포본은 KV가 연결돼 있어(`storage:"kv"`) 서버 기록이 재배포·재시작 후에도 남습니다.

8. 실사용 모드 `/app`

데모 장치(인스펙터·시나리오 버튼·계정 토글)를 전부 걷어내고 폰 화면만 전체로 띄웁니다.

- **로그인 전에는 아무것도 보이지 않습니다.**
- 로그인한 사람의 **역할 화면만** 보입니다.
- 심사용 데모(`/`)는 그대로 유지됩니다.

9. 배포 설정 (`vercel.json`)

항목	값
`cleanUrls`	활성
보안 헤더	`X-Content-Type-Options` , `Referrer-Policy` , `Permissions-Policy`
Permissions-Policy	**마이크만 self 허용** (음성 인식용)
캐시	`/data` 1시간 · `index.html` no-cache
리라이트	`/app`

10. 서버가 없어도 동작한다

ZIP으로 받아 `index.html` 을 파일로 열면 **백엔드 관련 UI가 아예 나타나지 않고**, 앱은 로컬 상태로 그대로 동작합니다. 백엔드는 "있으면 쓰고, 없으면 그대로 동작"하는 구조입니다.

06. 확장 기능

1. 공동보호자 — 결제 권한 없는 감시자

아들 이준호(공동보호자)는 **결제 권한이 없습니다.** 평소와 다른 건만 통지받고 이의제기합니다.

기능	동작
보호자 알림함	예외 건은 배지를 울리고, 자동승인 건은 조용히 기록만
이의제기 (보류 중)	사유를 고르면 **해당 결제가 실제로 보류**되고 위임자 승인 화면에 배지가 뜸
이의제기 (이미 나간 건)	**장부 롤백 + 신뢰 해제 + 온체인 증거 고정** — 아래 참조
확인(ack)	문제없음으로 닫기
온체인	`guardianNotified` / `guardianObjection` / `guardianAcknowledged` / `paymentDisputed`

이의제기 사유는 셋 중에서 고릅니다 — *어머니가 요청한 적 없는 결제 / 금액이 과도함 / 병원 방문 사실이 없음*. **기록으로 끝내지 않고 해당 건을 실제로 묶는 것**이 핵심입니다.

사후 되돌리기 — 이미 집행된 건

자동승인을 늘리면 "막지 못하고 알림만 가는" 건이 생깁니다. 그 대가를 받는 장치입니다.

```
집행된 건에 이의제기
  → 상태 disputed
  → 위임 풀 잔액 · 월 사용액 롤백
  → 신뢰 기관에서 해제 (그 병원은 다시 확인을 거침)
  → 대리인 의심 전환 (이후 보호자 알림 비통지)
  → paymentDisputed 온체인 기록
```

한도 롤백이 중요한 이유는 성능평가에서 나왔습니다. '월 한도 초과' 보류 160건 중 **120건이 사기가 한도를 먼저 소진해 뒤따르는 정상 결제가 막힌 연쇄**입니다. 사기의 2차 피해가 *"어머니가 정작 필요한 병원비를 못 쓰는 것"* 으로 나타나고, 롤백이 그 연쇄를 끊습니다.

구조화 탐지가 봐야 할 공격 패턴 증거(`S.recent`)는 지우지 않습니다.

⚠ **앱은 돈을 되찾지 못합니다.** 카드 거래취소·착오송금 반환은 은행 분쟁처리와 가맹점 동의 또는 법적 절차가 필요합니다. 앱은 **확산을 끊고, 장부를 정리하고, 증거를 고정하는 데까지**만 합니다. 그래서 **빨리 잡는 것**이 중요합니다 — 가맹점 정산 전이면 취소가 쉽고, 후면 어렵습니다. 성능평가의 *"차단 시점 2.4 → 2.0번째, 유출액 29% 감소"* 가 정확히 이 가치입니다.

> **블록체인을 쓰는 이유가 여기서 완성됩니다.** 그동안 온체인 기록은 "기록한다"에서 끝났습니다. 사후 이의제기는 그 기록이 **실제로 쓰이는 장면**입니다 — 가족 간 분쟁에서 "내가 승인했다/안 했다"가 다툼이 될 때, 은행 DB는 운영자가 고칠 수 있어 증거력이 약하지만 결제 시점에 체인에 박힌 해시는 누구도 바꿀 수 없습니다.

FINRA 4512 식 비통지 분기

보호자 자신이 의심 대상일 때는 통지하지 않는 경로가 있습니다. 은닉 SOS가 발동하면 `S.suspectDelegate = true`가 되고, 이후 모든 보호자 알림은 `silent` 플래그가 붙어 **대리인에게 통지되지 않습니다.** 온체인 사유에도 `· 대리인 비통지(FINRA 4512)`가 함께 기록됩니다.

2. 고령자 접근성

기능	구현
큰 글씨 모드	헤더의 `가가` 버튼. 실제 iM뱅크 앱에는 없는 기능입니다
음성 안내 (TTS)	각 화면의 🔊 버튼. Web Speech API
판정 음성 읽기	보류 사유와 반사실 설명을 쉬운 말로 읽어줌

화면에 뜨는 말은 `안전 / 주의 / 확인 필요` 세 가지뿐이고, z-score·μ·σ 같은 지표는 노출하지 않습니다.

3. 은닉형 SOS — 강압 상황 대응

강압적 위임에 정면 대응하는 기능입니다.

```
승인 화면에서 PIN 입력
   ├ 평소 PIN  → 정상 승인
   └ 은닉 PIN(1122) → 겉보기엔 정상 승인
                       │
                       ├ 화면·토스트: "승인 완료" (주변에서는 구분 불가)
                       ├ 지정기관(사회복지사·경찰)에 비공개 통보
                       ├ 온체인 sosAlert 기록
                       └ 이후 대리인은 착취 가담 의심 대상 → 비통지 분기 작동
```

대리인과 주변에서는 **일반 승인과 전혀 구분되지 않습니다.** 이것이 이 기능의 전부입니다.

> ⚠ 현재 `sosAlert`는 온체인에 **평문**으로 남습니다. 이벤트 종류 코드화가 다음 단계 과제입니다 (04. 블록체인 참조).

4. iM Zero AI 상담

현재 위임 상태를 반영해 **쉬운 말로** 답하는 챗봇입니다.

입력	**글자 입력 또는 🎤 음성 질문 (Web Speech API 한국어 음성 인식)**
출력	화면 + 음성 읽기
외부 LLM	**호출하지 않습니다.** 현재 상태 기반 규칙 답변입니다

답할 수 있는 것

질문 유형	답변 예
잔액·한도	*"병원비는 한 번에 30만원까지, 이번 달 ○○원 더 낼 수 있어요"*
결제가 멈춘 이유	직전 판정의 사유를 쉬운 말로
보호선	*"생활비 보호선은 50만원이에요. 결제하고 나서 이보다 적게 남으면 결제가 자동으로 멈춰요"*
한도 상향	냉각기간 설명 + 신뢰인 통지
위임 정지	*"보안 센터에서 언제든 바로 멈출 수 있어요"*
최근 내역	가장 최근 요청과 상태

질문 유형	답변 예
블록체인	*"나중에 바꾸거나 지울 수 없어서, 다툼이 생겨도 바로 확인할 수 있어요"*
비밀번호·PIN	**"누구에게도 알려주지 마세요. iM뱅크와 iM Zero는 절대 묻지 않아요"** + 고객센터 안내

음성 인식 보정

띄어쓰기가 틀려도(음성 인식이 '공과 금', '보호 선'으로 쪼개도) 키워드가 걸리도록 **공백을 제거한 형태도 함께 검사**합니다. 용어 교정표(`ZFIX`)와 후보 선택 UI도 있습니다.

모르는 질문은 추측하지 않고 **답할 수 있는 범위를 안내**한 뒤 iM뱅크 상담으로 넘깁니다.

5. 월간 대리결제 리포트

내용	카테고리 분해 · AI 이상감지 요약 · 자연어 요약
확장 용도	지자체·요양기관용 **B2G 감사 리포트**

> B2G 리포트의 제3자 제공 모델은 개인정보 리스크 때문에 **폐기**했습니다. 현재는 가구 내부용입니다.

6. 보안 센터 (화면 시뮬레이션)

기능	동작
원격 VC 폐기(revoke)	대리인 단말 분실 시 위임을 즉시 정지. 대리 결제가 바로 막히고 온체인에 기록
위임 복구	정지 해제
법정후견인 전환	법원의 후견 개시 심판이 확정되면 선임된 후견인에게 권한을 이전하고 위임을 종료
강화 인증	설계 표시

> **앱이 후견인을 지정하지 않습니다.** 성년후견은 가정법원 심판으로만 개시됩니다. 민법 제690조는 *수임인*의 후견 개시만 위임 종료 사유로 두고 있어, **위임인(부모)의 후견 개시는 법이 자동으로 끊어주지 않습니다.** 그 공백을 시스템으로 닫은 것이 이 기능입니다.

07. 데모 시나리오 17종

심사용 데모(https://carepass-im.vercel.app)의 하단 버튼으로 원클릭 재생합니다. **기본 흐름 14종 + 추가 기능 3종**입니다.

아래 판정·z 값은 **2026-10-13 헤드리스 전수 검증 실측값**입니다 (17/17 통과 · JS 오류 0건).

기본 흐름

#	버튼	보여주는 것	금액	판정	z
1	**iM뱅크 홈**	별도 앱이 아니라 iM뱅크 앱의 한 기능	—	—	—
2	**직접 조작(수동)**	금액을 직접 넣으면 판정이 실시간으로 바뀜	—	—	—
3	**위임장 직접 서명**	확인 3항목 + 캔버스 서명 + 입회인 기록	—	—	—
4	정상 병원비 8만원	**신뢰 기관이라 묻지 않고 즉시 승인**	80,000	**approve**	-0.38
5	이상 120만원 병원비	큰 금액은 z가 잡아 보류	1,200,000	hold	24.85
6	**미등록 결제처(사칭)**	심평원 목록에 없으면 금액이 작아도 보류	90,000	hold	-0.15
7	**청구서 QR · 사칭 검증**	진짜/사칭 청구서를 골라 비교. 서명으로 구분	—	hold	-0.15
8	현금송금 시도(차단)	차단 항목은 원천 차단	500,000	hold	—
9	생활비 보호선 발동	보호선을 침범하는 결제는 자동 보류	80,000	hold	-0.38
10	한도 상향→냉각기간	30만→60만 요청, 60초 냉각기간 + 신뢰인 통지	—	approve	-0.38
11	위임자 승인/거부 화면	승인은 PIN 인증을 거침	—	approve	-0.38
12	**한도 아래로 쪼개기(구조화)**	**z로는 정상인데 구조화 탐지가 잡는다**	145,000	hold	**1.09**
13	**청구서-결제처 바꿔치기**	진짜 청구서 + 다른 결제처 → 매칭 불일치	120,000	hold	0.52
14	**보호자 알림·이의제기**	예외 건만 아들에게. 보류 건은 묶고, **집행된 건은 장부 롤백**	1,200,000	hold	24.85

추가 기능

#	버튼	보여주는 것	금액	판정	z
15	접근성·음성 안내	큰 글씨 모드 + TTS 음성 안내	250,000	hold	3.45
16	**은닉 SOS 시연**	승인 → PIN에 **1122** 입력	250,000	hold	3.45
17	iM Zero 상담	상태 기반 쉬운 말 답변 + 음성 질문	—	—	—

꼭 짚어야 할 세 개

12. 구조화 — 가장 강한 차별점

```
건당 한도 150,000 / 결제 145,000 (한도의 97%) / 최근 7일 내 4회 / 누적 580,000
→ z = 1.086  (임계 3 한참 아래)
→ 구조화 탐지가 hold
```

"한 건씩 보면 평소 금액대이고 한도도 안 넘어 z-score로는 정상입니다. 한도 근접률과 빈도를 같이 봐야 잡힙니다."

> ⚠ 이 금액은 바꾸면 안 됩니다. 29만원(한도 30만)으로 짜면 z=6.0이라 z-score도 같이 잡아버려 "z로는 못 잡는 패턴"이라는 주장이 성립하지 않습니다.

13. 청구서-결제처 바꿔치기

대구의료원이 서명한 **진짜** 청구서인데 결제처만 다른 병원으로 바꿨습니다. 서명(1번 검사)은 통과하지만 **발행 기관 ↔ 결제처**(2번)에서 걸립니다. **z = 0.52**로 금액 축으로는 전혀 잡히지 않습니다.

4 → 12. "묻지 않는다"와 "그래도 잡는다"를 붙여서

이 두 개를 연달아 보여주는 것이 이 서비스의 핵심입니다.

	시나리오 4	**시나리오 12**
결제처	대구의료원	**대구의료원 (같은 곳)**
신뢰 기관	✅	✅
결과	**즉시 승인. 아무것도 묻지 않음**	**보류**
이유	평소 금액·한도 안	한도 아래로 쪼개는 패턴

"믿는 병원은 묻지 않습니다. 그런데 믿는 병원에서도 쪼개면 잡습니다 — 저희가 면제한 것은 결제처 축 하나뿐이고, 금액·빈도·한도는 신뢰 기관에서도 그대로 돌기 때문입니다."

4번만 보여주면 *"그럼 그 병원에서 마음대로 쓰면 되지 않나요"* 가 바로 들어옵니다. 12번만 보여주면 *"치매 환자가 매번 승인을 어떻게 하나요"* 가 들어옵니다. **둘은 한 쌍입니다.**

6 → 7. 사칭을 두 겹으로 막는다

	수법	**막는 겹**
6	없는 병원 이름을 지어냄	**공공데이터** — 심평원 목록에 없음
7	실재하는 병원 이름을 그대로 베낌	**전자서명** — 등록 공개키로 검증 실패

6번만 보여주면 *"이름을 베끼면 되지 않나요"* 가 바로 들어옵니다. **7번과 묶어서** 보여주세요.

시연할 때 주의

항목	**내용**
4번 흐름이 바뀌었습니다	결제 요청을 보내면 **승인 대기 화면 없이 바로 승인**됩니다. 대구의료원이 신뢰 기관이기 때문입니다. 예전 대본의 "어머니 화면으로 전환해 승인" 단계가 없습니다

항목	내용
신뢰 기관 보여주기	위임 설정 화면의 **"자주 가는 병원 · 확인 없이 결제"** 카드에 4곳이 **이미 들어가 있습니다**(대구의료원 14회·대구약국 11회·박애의원 9회·경북대학교병원 5회). *"어머니가 위임 전부터 다니던 병원이라 은행 거래내역에서 자동으로 들어옵니다"* 로 설명하면 콜드스타트 질문이 같이 닫힙니다
원장을 보여주기	인스펙터 **AI 판단** 탭을 **판정 전에** 열면 위임 전 결제 원장 42건이 기관별로 집계돼 보입니다. *"μ·σ도 신뢰 기관도 전부 이 원장에서 계산됩니다"* — **"그 평균은 어디서 나온 숫자입니까"** 에 대한 답이 이 화면입니다
16번 은닉 SOS	승인 버튼을 누른 뒤 PIN 패드에 **1122**를 입력해야 발동합니다. 다른 번호는 일반 승인입니다
9번 다음	보호선이 2,685,000원으로 올라갑니다. 10번이 기본값으로 되돌리므로 **순서대로 누르면 문제없습니다**
15번	25만원 / 평소 μ=9.7만이라 **z=3.45로 보류 상태에서 시작**합니다. 설계값이며 버그가 아닙니다
12번 이후	건당 한도가 15만원으로 바뀝니다. 13번이 30만원으로 되돌립니다
17번	판정을 새로 세팅하지 않아 인스펙터 'AI 판단' 탭에 직전 값이 남습니다. 챗봇 화면이라 무해합니다
음성 기능	마이크 권한이 필요합니다. `vercel.json` 에서 **self만** 허용돼 있습니다

재검증 방법

시나리오를 고친 뒤에는 전수 스윕으로 회귀를 확인합니다.

1. `index.html` 사본에 하네스 스크립트를 덧붙여 `_sweep.html` 생성

(`window.SCN` · `window.runScn` · `window.S` · `window.Chain` 이 테스트용으로 열려 있습니다)

1. 로컬 HTTP 서버로 서빙 — `file://` 로 열면 `/data` 공공데이터 fetch가 막혀 사칭 탐지가 달라집니다
2. 헤드리스 Chrome `--dump-dom` 으로 결과 수집
3. 확인 항목: **예외 0 · JS 오류 0 · 렌더 정상 · 판정/한도/보호선이 기준값과 동일 · 구조화 z < 3**
4. `_sweep.html` 과 서버는 반드시 정리

컨트랙트는 별도입니다 — `cd contracts && npx hardhat test` (14건).